BAHRIA UNIVERSITY
Discovering Knowledge

Multi-Topic in Security

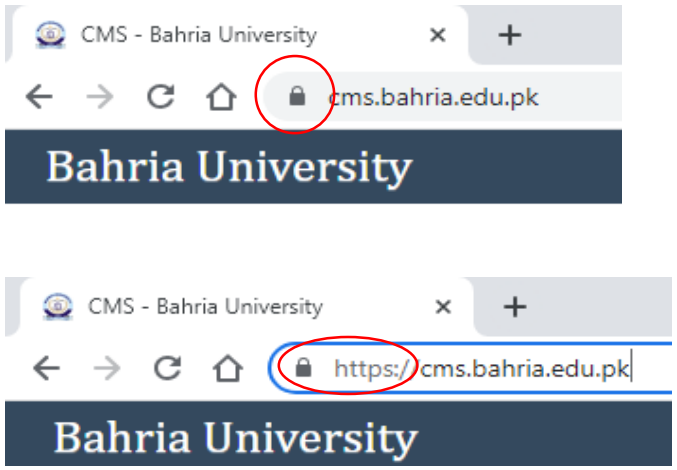
Data Encryption & Security (CEN-451)

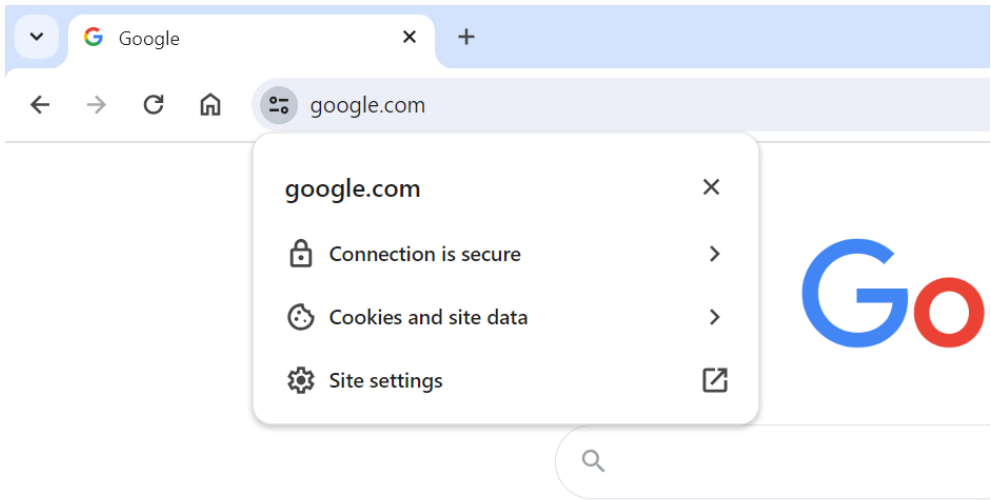
Spring 2025 (BSE-8A&B)

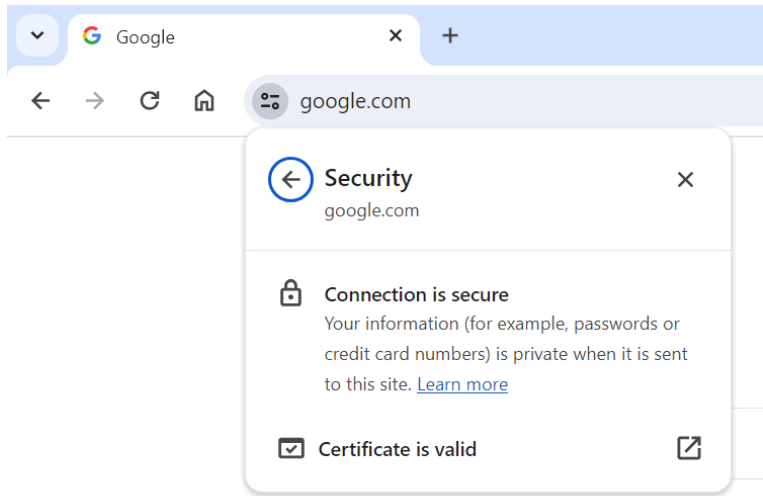
Hyper Text Transfer Protocol Secure (HTTPS)

HTTPS

- **HTTPS** (port **443**) is the secure version of **HTTP** (port **80**).
- **HTTPS encrypts** all communications between **browser** and the **website**. Web browsers, ***e.g. Chrome***, display a **padlock** icon in the address bar to visually indicate **HTTPS** is in effect.

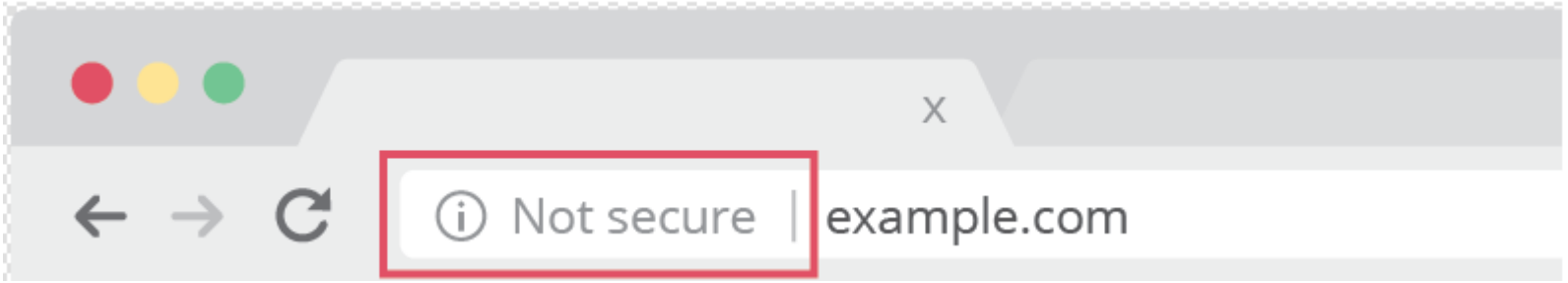




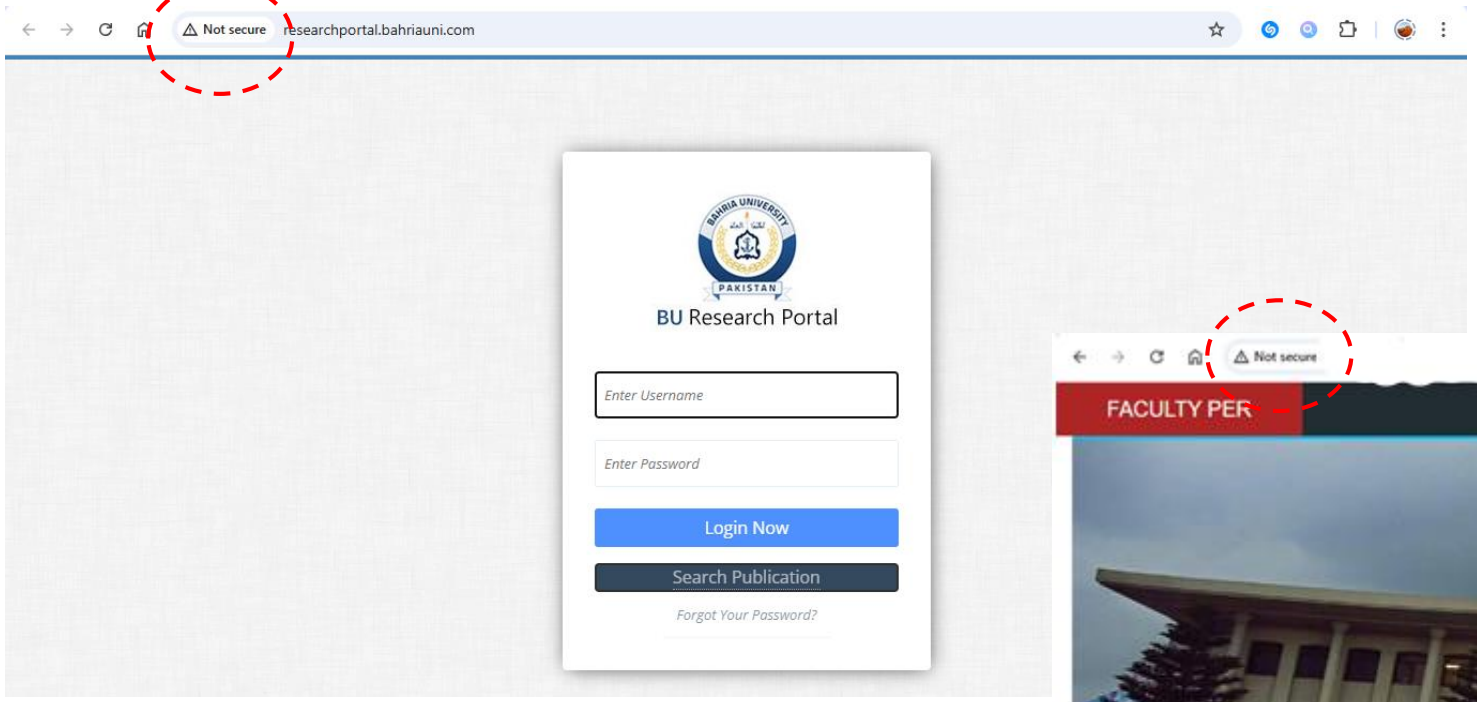


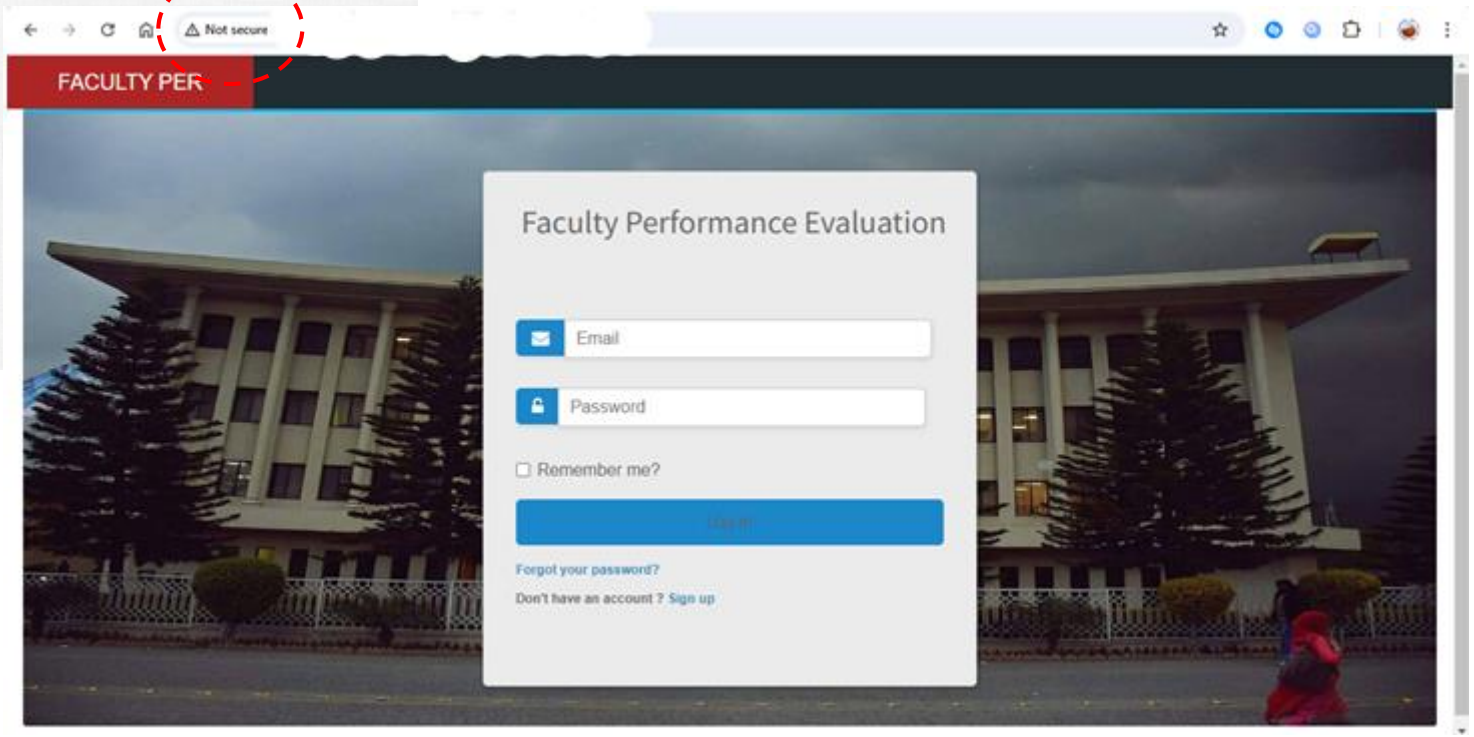
HTTPS (Cont.)

- Web browsers that take **HTTPS** seriously, *e.g. Google Chrome*, flag all **non-HTTPS** websites as **"not secure"**.
- Starting July 2018 with release of *Chrome 68*, all unsecured **HTTP** traffic has been flagged in the URL bar as **"not secure"**.
- The **"not secure"** notification appears for all websites without a **valid certificate**.



HTTPS (Cont.)

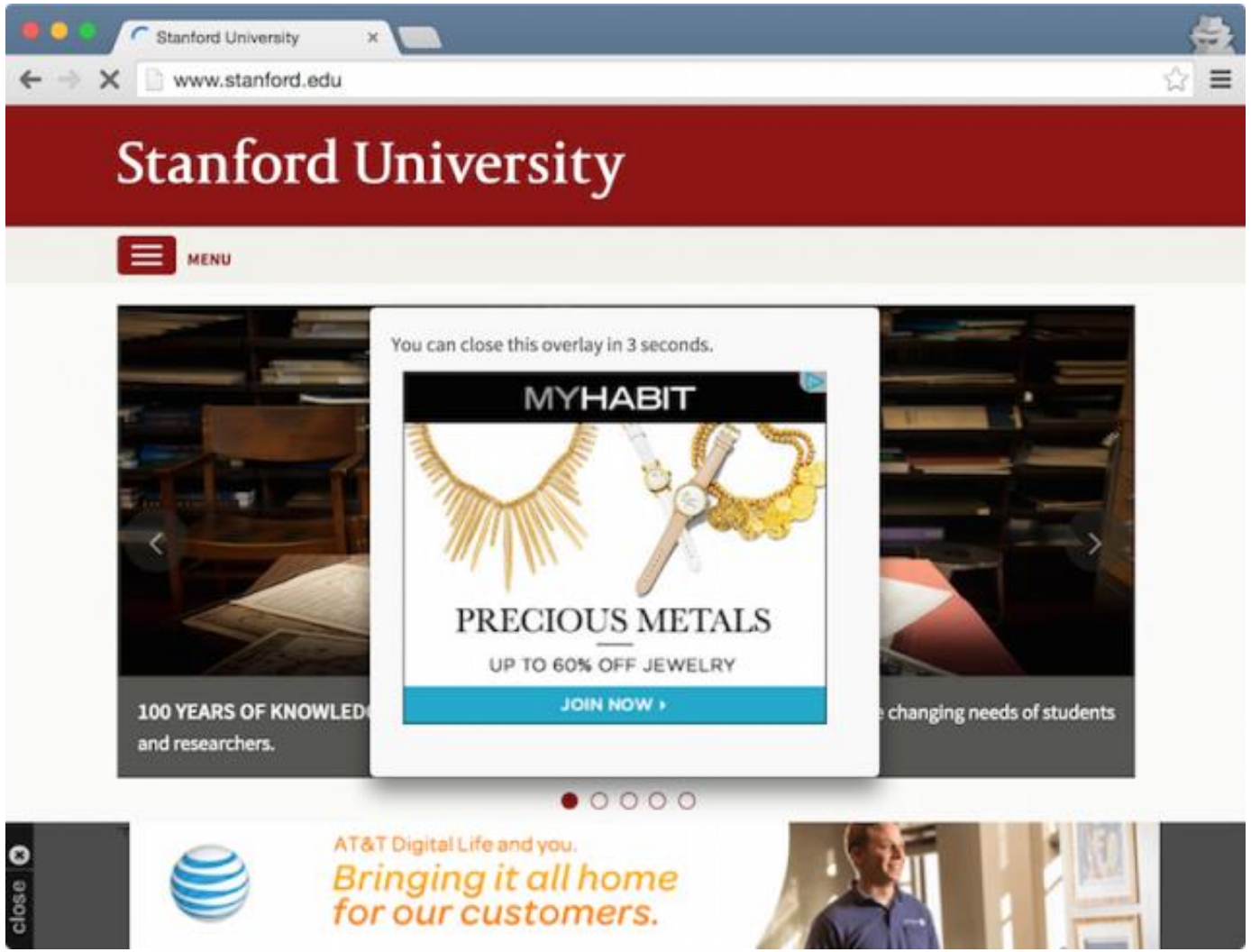

Not secure
researchportal.bahriauni.com
BU Research Portal
Enter Username
Enter Password
Login Now
Search Publication
Forgot Your Password?


Not secure
FACULTY PER
Faculty Performance Evaluation
Email
Password
Remember me?
Forgot your password?
Don't have an account ? Sign up

HTTPS Importance

- **HTTPS** is particularly important when users transmit **sensitive data**, such as logging into a bank account or email service.
- Traffic encrypted with **HTTPS** would be unintelligible if the packets are sniffed or intercepted.
- In websites without **HTTPS**, it is possible to inject content into webpages without approval of the website owner ***(e.g. Ads)***.

HTTPS Importance (Cont.)



HTTPS Areas of Protection

- **HTTPS** provides three important areas of protection:

1. **Encryption:** encryption covers:
   - **URL** of the requested document.
   - **Contents** of the document.
   - Contents of **browser forms** ***(filled in by browser user)***.
   - **Cookies** sent from browser to server and from server to browser.
   - Contents of the **HTTP header**.

HTTPS Areas of Protection (Cont.)

- **HTTPS** provides three important areas of protection (Cont.):

2. **Data integrity:** data cannot be modified / corrupted during transfer, ***intentionally or unintentionally***, without being detected.
3. **Authentication:** proves that users communicate with ***intended website***. It protects against **man-in-the-middle** attacks and builds user trust.

HTTPS and TLS/SSL

- Technically, **HTTPS** is not a separate protocol from **HTTP**!
- **HTTPS** is simply using **Transport Layer Security (TSL) / Secure Sockets Layer (SSL)** encryption over **HTTP**.
- **HTTPS** occurs based upon the transmission of **TLS/SSL** certificates.
- When a ***user (client)*** connects to a ***webpage (server)***, the webpage will send over its **TLS/SSL certificate** which contains the **public key** necessary to start the secure session.
- The **client** and **server** go through a process called an **TLS/SSL handshake**, which is a series of back-and-forth communications used to establish a secure connection.

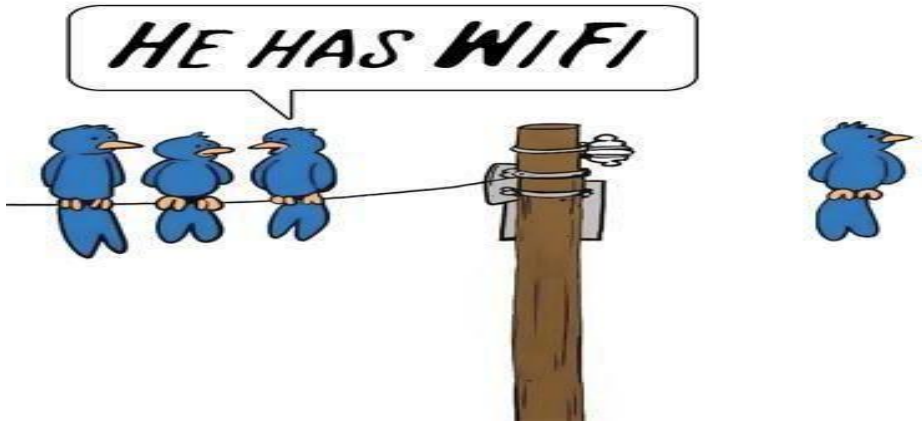
HTTPS and TLS/SSL (Cont.)

- **TLS** secures communications by using **asymmetric public key** infrastructure, which uses two different keys:
  1. **Public key:** is available to everyone who wants to interact with the **server**. Information encrypted by **public key** can only be decrypted by **private key**.
  2. **Private key:** is controlled by **owner of website** and it is kept as private. This key lives on a **web server** and is used to decrypt information encrypted by the **public key**.

Wireless Security

Wireless Networks

- **Wireless networks** ***(compared to wired networks)*** are cheaper and easier to install and maintain.
- However, attackers easily compromise a wireless network that is not properly **secured** or **configured**.
- In wireless networks, it is vital to determine ***Critical sources, Vulnerabilities*** and ***Risks.***



Security Risks in Wireless Networks

- Key factors that contribute to higher security risk in wireless networks include:
  a. **Channel:** wireless networking typically involves **broadcast communication** channels, which is far more susceptible to **eavesdropping** and **jamming** than wired networks.
  b. **Mobility:** wireless devices are far more portable and mobile than wired devices.
  c. **Resources:** some wireless devices, such as ***IoT / Embedded Devices***, have ***limited memory*** and ***processing resources*** to counter threats, including DoS and malware.

Security Risks in Wireless Networks (Cont.)

- Key factors that contribute to higher security risk in wireless networks include (Cont.):

  d. Accessibility: some wireless devices, such as sensors and robots, may be **left unattended** in remote and/or hostile locations. This greatly increases their vulnerability to **physical attacks**.

Wireless Network Threats

Common security threats to wireless networks are:

1. **Malicious association:** a wireless device is configured to appear as a **legitimate access point**, enabling the operator to steal sensitive information from legitimate users.
2. **Ad hoc networks:** peer-to-peer networks between wireless computers with no access point between them, posing a security threat due to **a lack of a central point of control**.
3. **Man-in-the middle attacks / Denial of service (DoS):** Wireless networks are particularly vulnerable to such attacks due **to ease of access** and use for the attack.

Wireless Security Measures

1. **Securing Wireless Transmissions:**
   a. **Encryption:** encryption of all wireless transmission is effective against **eavesdropping**.
   b. **Signal-hiding techniques:** organizations can take several measures to make it difficult for attacker to locate the APs:
      - Turning off **service set identifier (SSID)** broadcasting by APs.
      - Assigning **cryptic names** to SSIDs (e.g. ***VIRUS.EXE***)
      - Reducing **signal strength** to the lowest level that still provides requisite coverage.
      - Use of **directional antennas** and **signal-shielding** techniques.

Wireless Security Measures (Cont.)

2. Securing Wireless Access Points:

- The main threat involving wireless access points is **unauthorized access** to the network.
- The principal approach for preventing unauthorized access is the **IEEE 802.1X** standard for ***port-based network access control (PNAC).***
- **PNAC** provides an authentication mechanism to devices wishing to attach to a LAN or WLAN.

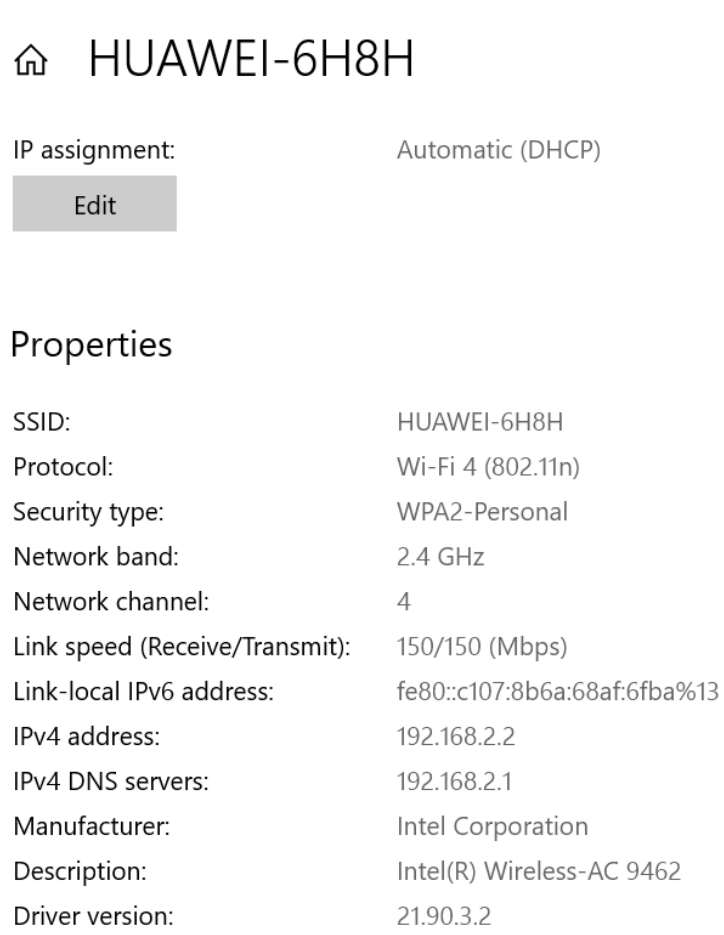
Wireless Security Measures (Cont.)

3. Securing Wireless Networks:

- Use **antivirus**, **antispyware** and **firewall**.
- Change router's **pre-set password** for administration.
- Allow only **specific computers** to access your wireless network. E.g. a router can be configured to only communicate with **approved MAC addresses**.

The Wi-Fi Alliance

- The **Wi-Fi Alliance** has developed certification procedures for **IEEE 802.11 security standards**, referred to as **Wi-Fi Protected Access (WPA)**.
- **WPA**, **WPA2** and **WPA3** are three security certification programs developed by Wi-Fi Alliance in response to serious weaknesses found in **Wired Equivalent Privacy (WEP)**.

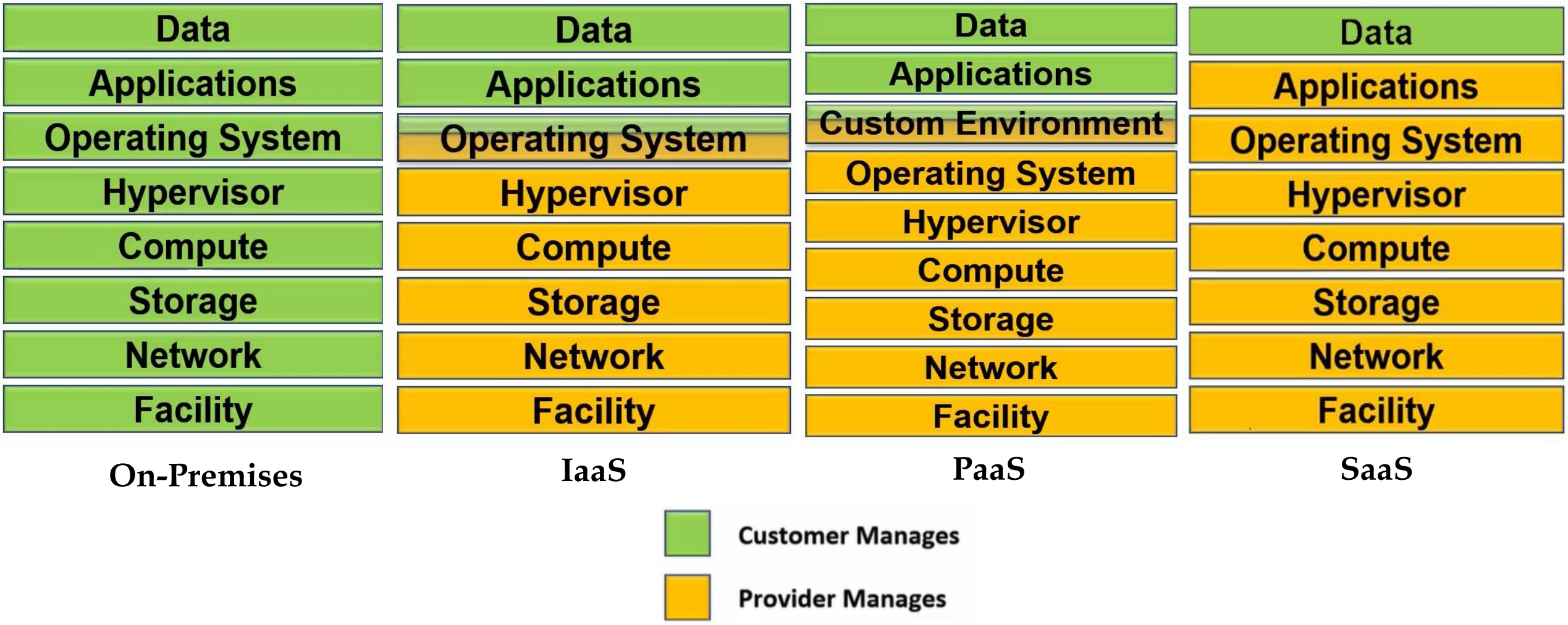


Cloud Security

Cloud Security: Shared Responsibility

- Cloud security and compliance are the **shared responsibility** of the ***cloud provider and consumer***, divided based on the shared **responsibility model**.
- Different cloud service models ***(IaaS, PaaS, and SaaS)*** imply varying levels of controls between the **cloud service providers** and **cloud consumers**.

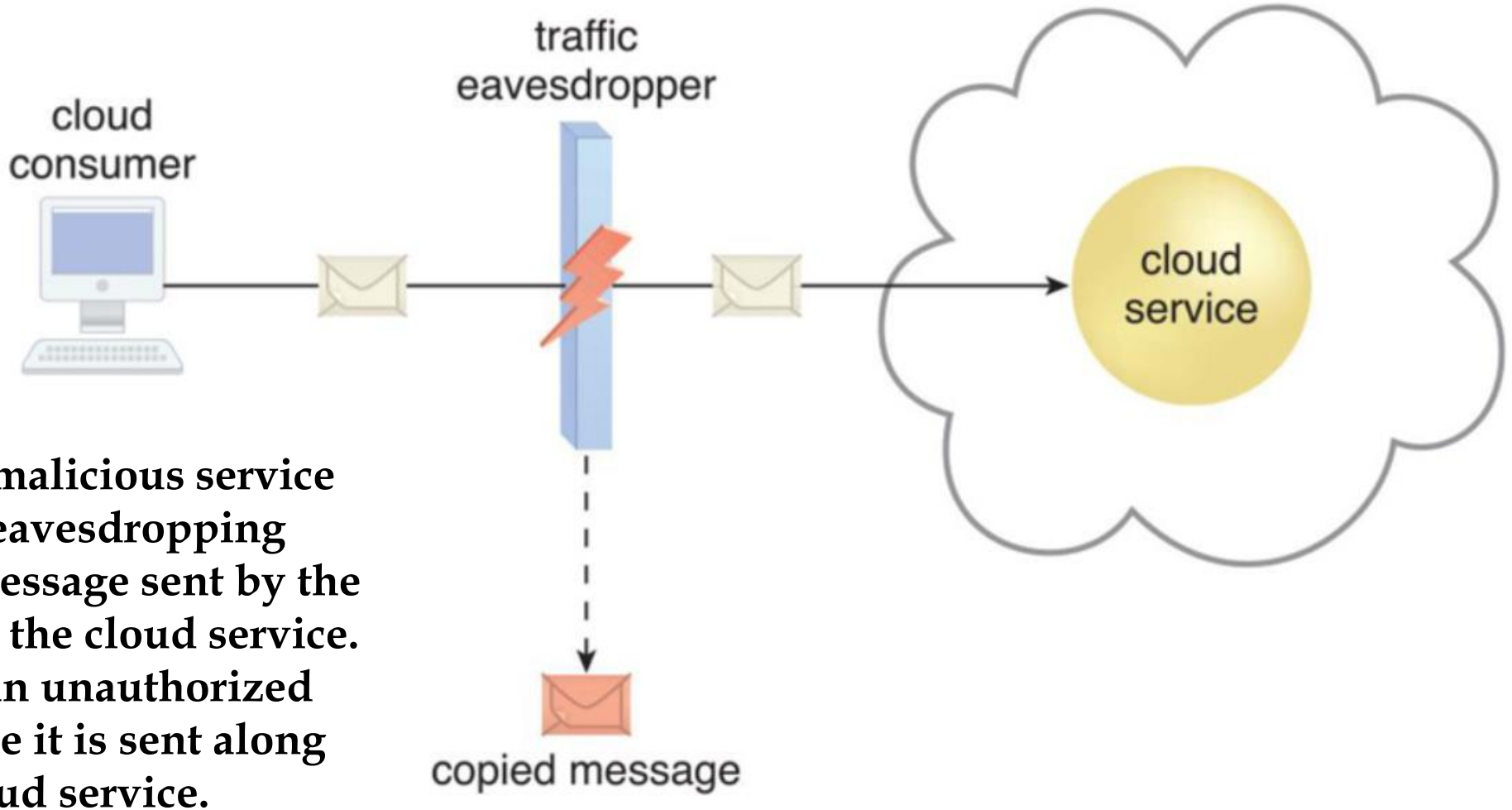
Cloud Security: Shared Responsibility (Cont.)



Traffic Eavesdropping

- Occurs when data being transferred to a cloud ***(usually from the cloud consumer to cloud provider)*** is **passively** intercepted by a malicious service agent.
- The aim of this attack is to directly compromise **confidentiality** of the data.
- Because of the passive nature of the attack, it can **more easily go undetected** for extended periods of time.

Traffic Eavesdropping (Cont.)

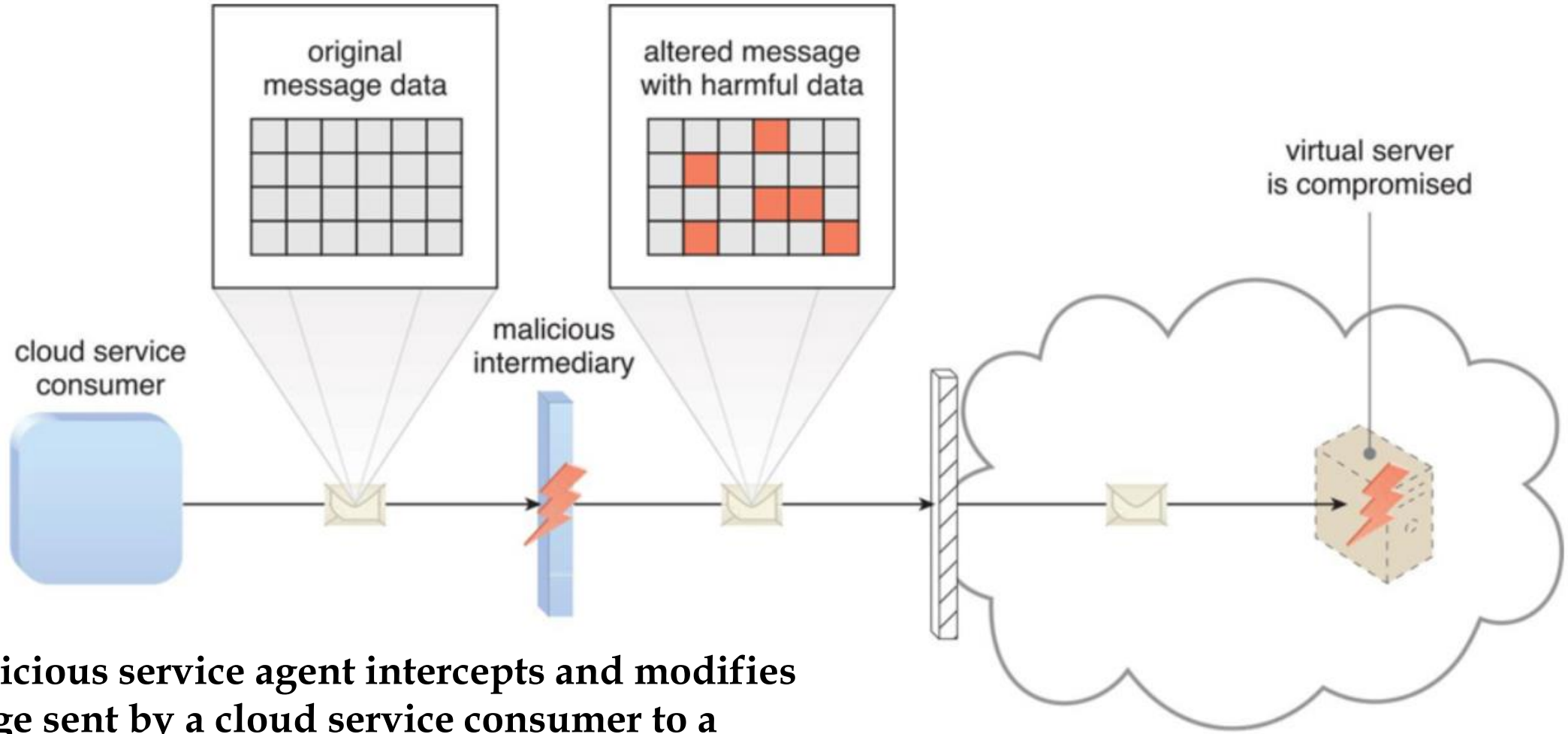


An externally positioned malicious service agent carries out a traffic eavesdropping attack by intercepting a message sent by the cloud service consumer to the cloud service. The service agent makes an unauthorized copy of the message before it is sent along its original path to the cloud service.

Malicious Intermediary / MiTM

- The malicious intermediary threat arises when messages are **intercepted** and **altered** by a malicious service agent
- It attempts to compromising message's **confidentiality and/or integrity**.
- It may also insert harmful data into the message before forwarding it to its destination.

Malicious Intermediary / MiTM (Cont.)



The malicious service agent intercepts and modifies a message sent by a cloud service consumer to a cloud service being hosted on a virtual server.

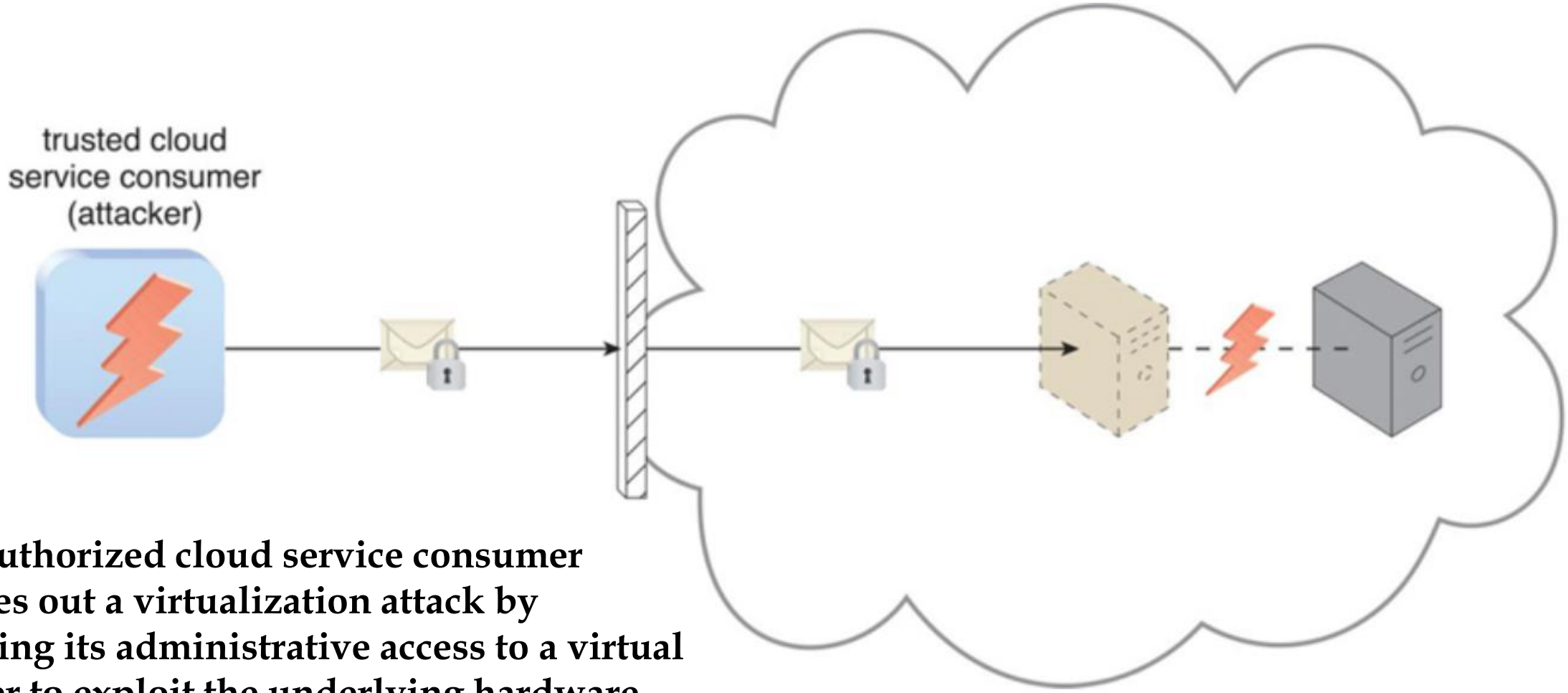
Botnet & DDoS

- A bot is a **malware** capable of receiving and acting upon instructions issued by a remote attacker.
- A **botnet** attack utilizes multiple bots that are distributed across different hosts to carry an attack via a coordinated network of bots.
- A common technique for carrying out a botnet attack is to start with an initial malware infection to create **"zombie"** hosts.
- A **zombie host** is a computer that belongs to legitimate organization that an attacker has taken control of.
- The attacker then typically uses the zombie host to carry out attacks against another party, e.g. **DoS/DDoS attacks**.

Virtualization Attack

- Virtualization provides multiple cloud consumers with access to IT resources that ***share underlying hardware*** but are logically isolated from each other.
- Because cloud providers grant cloud consumers ***administrative access to virtualized IT resources*** (e.g. virtual servers), there is an **inherent risk** that cloud consumers could abuse this access to attack the underlying **physical IT resources**.
- A **trusted attacker** successfully accesses a **virtual server** to compromise its underlying **physical server**.

Virtualization Attack (Cont.)



An authorized cloud service consumer carries out a virtualization attack by abusing its administrative access to a virtual server to exploit the underlying hardware.

Containerization Attack

- Since containers deployed on the same machine ***share the same host OS***, security threats can increase because ***access to the entire system can be gained***.
- If the underlying host OS is compromised, all containers running on the host may be impacted.

Q) What would be the solution?

Containerization Attack (Cont.)

- Containers can be created from within an OS running on a **virtual server**.
- This can help ensure that if a security breach occurs that impacts the OS a container is running on, the attacker ***can only gain access to and alter the virtual server's OS*** or ***the containers running on a single virtual server***.
- Other virtual servers or physical servers remain **intact**.

Cloud Security Mechanism

Single Sign-On System

- Propagating **authentication** and **authorization** information for a **cloud consumer** across multiple cloud services or cloud-based IT resources can be a challenge.

SOLUTION

- **Single sign-on (SSO):** an authentication method that enables users to securely authenticate with multiple applications and websites by using just one set of credentials.



Single Sign-On System (Cont.)

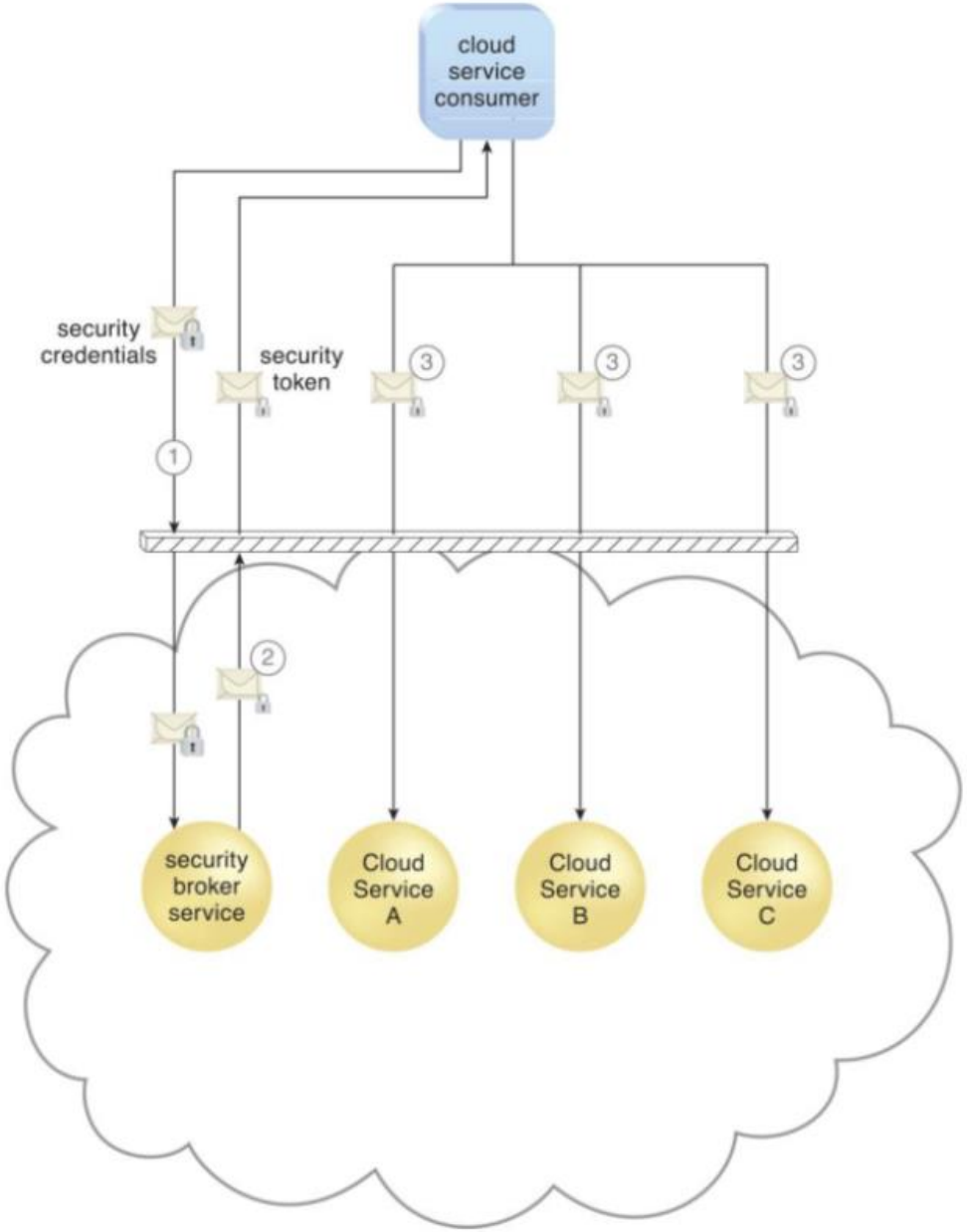
- **Single sign-on (SSO)** system enables one **cloud consumer** to be authenticated by a **security broker**.
- The **security broker** ***(identity provider)*** establishes a **security context** ***(takes the form of tokens)*** that is continued while the **cloud consumer** accesses other cloud services.
- Otherwise, the **cloud consumer** would need to ***re-authenticate itself with every subsequent request***.

Single Sign-On System (Cont.)

- The credentials initially provided by the **cloud consumer** remain valid for the ***duration of a session***, while its **security context** information is shared,
- **SSO** mechanism is especially useful when a **cloud consumer** needs to access cloud services residing on **different clouds**.

Single Sign-On System (Cont.)

A cloud service consumer provides the security broker with login credentials (1). The security broker responds with an authentication token upon successful authentication, which contains cloud service consumer identity information (2) that is used to automatically authenticate the cloud service consumer across Cloud Services A, B, and C (3).

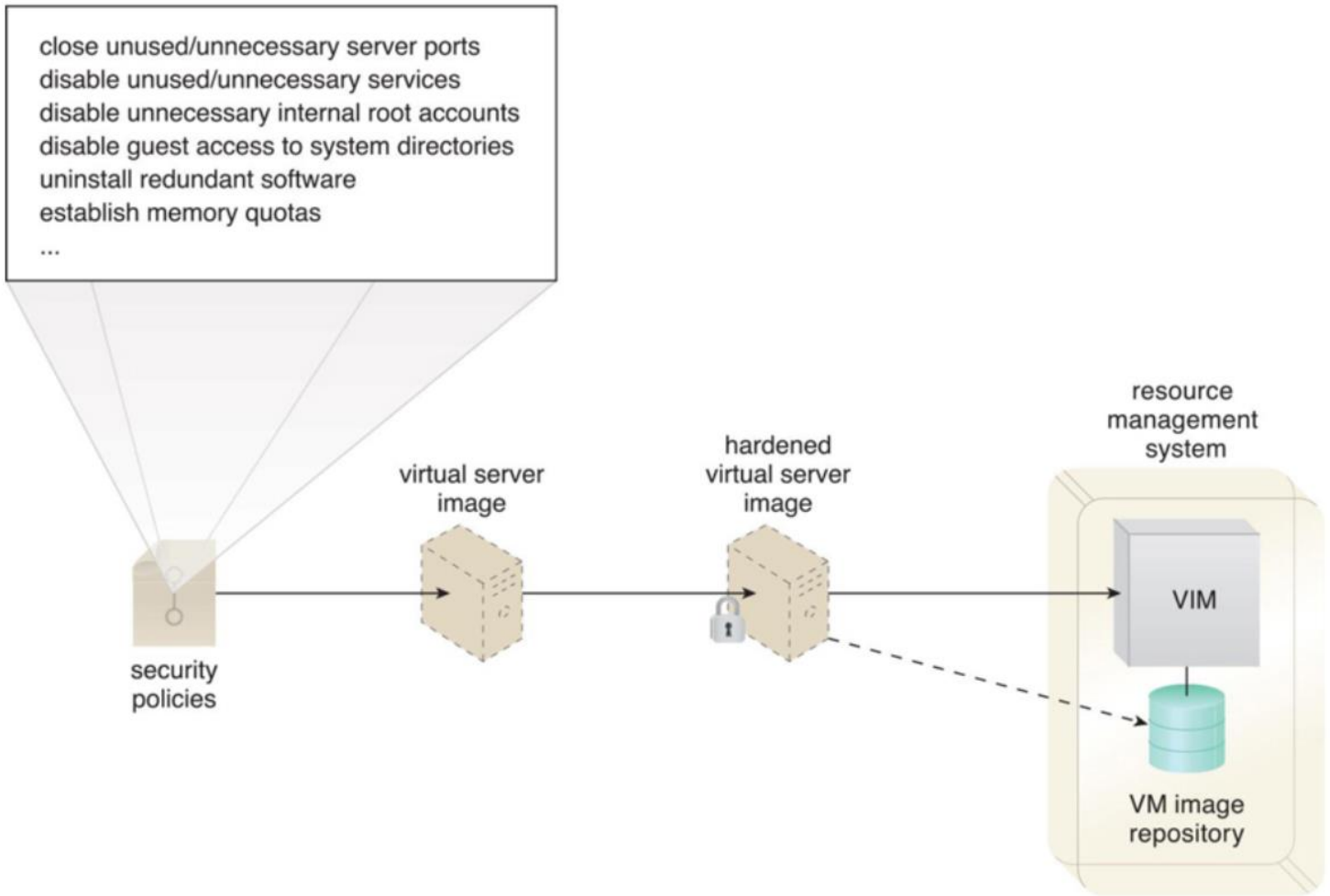


Hardened Virtual Server

- Usually, virtual server is created from a **template configuration** called a **virtual server image (or VM image)**.
- Hardening is the process of ***stripping unnecessary software from a system to limit potential vulnerabilities that can be exploited by attackers***.
- **Examples of hardening;** removing redundant programs, closing unnecessary server ports, and disabling un-used services, internal root accounts, and guest access.

Hardened Virtual Server (Cont.)

- A hardened ***virtual server image*** is a **template** for virtual server instance creation that has been subjected to a hardening process.
- This generally results in a **virtual server template** that is significantly more secure than the original standard image.

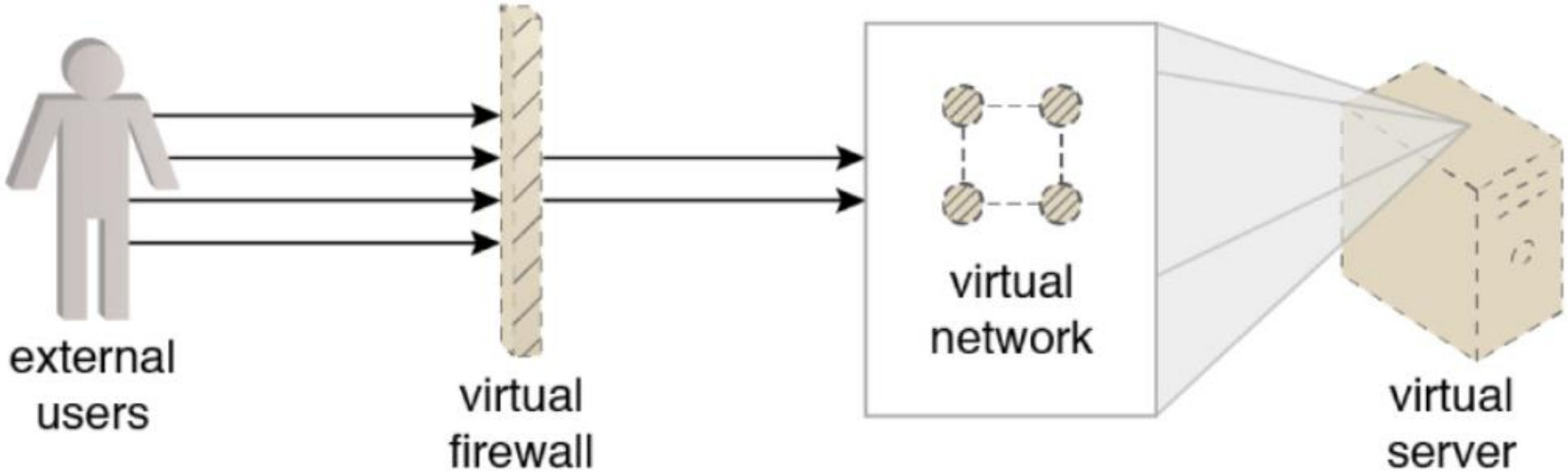


Virtual Firewalls

- Firewalls control traffic flow by intercepting all traffic that goes **in and out** and identifying whether any of that traffic matches **predefined rules**.
- A **physical firewall** protects physical connections to network devices. However, **physical firewalls** are not capable of filtering traffic that belongs to **virtual networks** ***(exist only within virtualized hosts)***.
- In such an environment, a **virtual firewall** can be deployed to provide the same kind of protection for the **virtual network**.

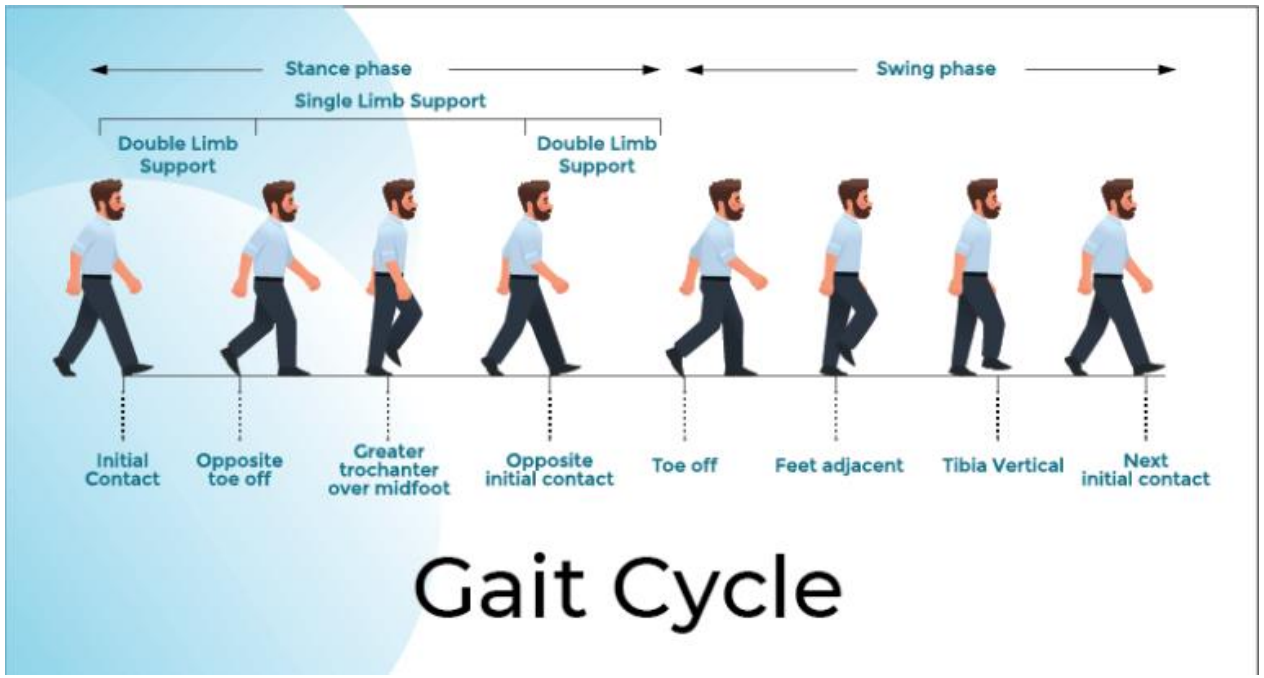
Virtual Firewalls (Cont.)

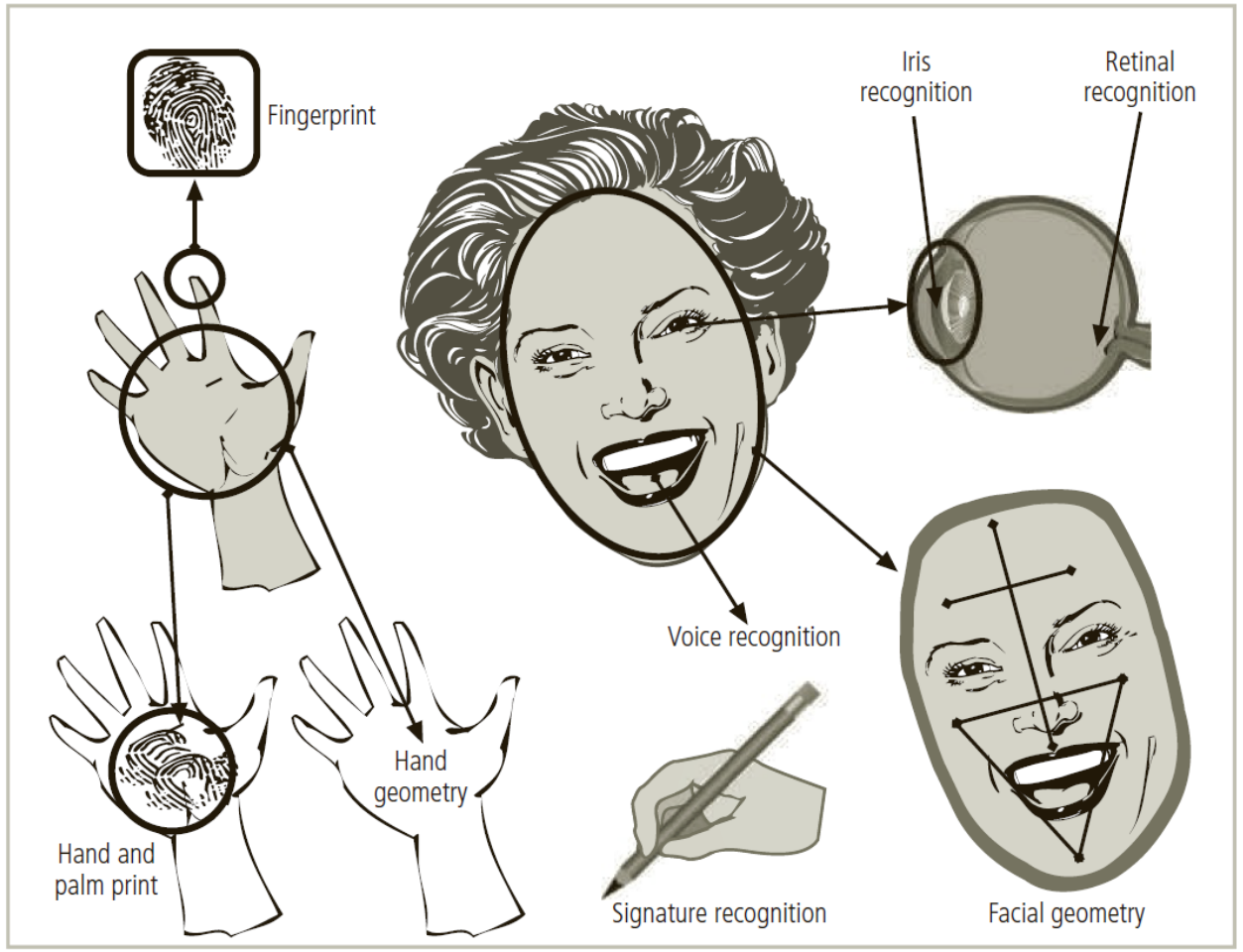
- It is common for **virtual and physical firewalls** to be integrated so as to provide coordinated protection that encompasses physical and virtual networks.



Biometric Scanner

- Biometrics is a technology used to determine a **person's identity** based on their **physiological** or **behavioral** characteristics.
- Since biometric data is directly derived from unique user characteristics, ***it cannot be lost, forgotten nor easily forged***.
- **Physiological Identifiers** – include ***fingerprints, hand shape or vein pattern, eyes (including iris and retina) and face shape***.
- **Behavioral Identifiers** – include ***voice recognition, signature dynamics (speed of pen movement, pressure exerted and inclination), keystroke dynamics, gait***.


Stance phase
Swing phase
Single Limb Support
Double Limb Support
Double Limb Support
Initial Contact
Opposite toe off
Greater trochanter over midfoot
Opposite initial contact
Toe off
Feet adjacent
Tibia Vertical
Next initial contact
Gait Cycle


Fingerprint
Iris recognition
Retinal recognition
Voice recognition
Hand and palm print
Hand geometry
Signature recognition
Facial geometry

Biometric Scanner (Cont.)

- Physiological measurements usually offer the benefit of ***staying stable throughout the lifetime***.
- Behavioral measurements can ***change with different life stages***.
- Some biometric scanner combine different types of biometric parameters to increase the range of security validations and the accuracy of identifications ***(i.e. multimodal biometric scanners)***.
- **Multimodal biometric scanners** require at least two biometric credentials to perform identification ***(e.g. both facial and fingerprint recognition)*** to validate a user.

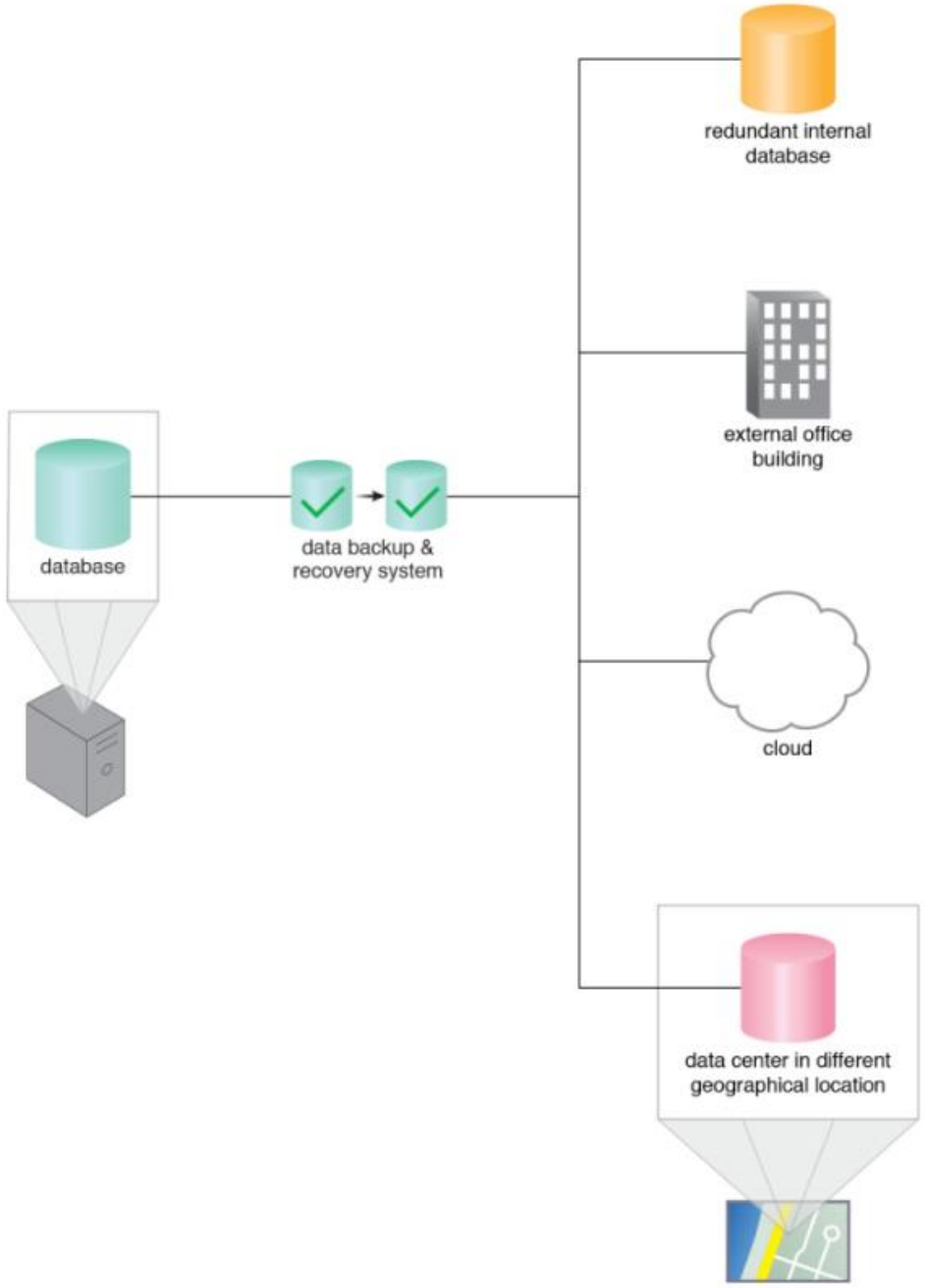
Data Backup & Recovery

- Data backup and recovery system is a mechanism used to provide **fast data recovery** in the event of data loss or corruption resulting from ***cyber-attacks, cyber theft, physical theft and hardware and software failure***.
- Data backup and recovery system essentially ***copies important data to separate storage repositories*** to provide a constant fallback for an organization to recover data.

Data Backup & Recovery

A common technique for using the data backup and recovery system is known as the **"3-2-1 approach".**

The basic concept of the 3-2-1 backup strategy is that ***three copies of the data are made to be protected, the copies are stored on two different types of storage media and one copy of the data is sent offsite in a different geographical region.***



Data Backup & Recovery (Cont.)

3-2-1 Backup Rules:

- **Three copies of data:** maintain three copies of data, including the original and at least two copies.
- **On two different media:** data is to be stored on two different forms of media. This can help reduce any impact that may be attributable to one specific storage media type.
- **One copy off-site:** one copy of data should be kept off-site in a remote location, ideally more than a few miles away from the other two copies.

Data Backup & Recovery (Cont.)

- In 3-2-1 backup scenario, **backup software** is used to make a copy of the company's critical data, with a copy of the data saved to another **on-premises** data storage device.
- One of the traditional storage medium includes **tape library**.
- However, **tape** has been replaced by a **hard-drive** storage.



Data Backup & Recovery (Cont.)

- Many variations of this mechanism rely on ***placing backup data in clouds***.
- Cloud providers often provide **backup-as-a-service (BaaS)** offerings.
- **BaaS** can simplify data backup and recovery because they do not require the need to ***install and configure a storage device and additional software***.

Cloud Security: The Way Forward

AWS Call for Proposal

https://www.amazon.science/research-awards/call-for-proposals

amazon | science

Research areas | Blog | Publications | Conferences | Code and datasets | Academia | Careers | Newsletter

Amazon Research Awards

Program updates | Research stories | Recipients | Rules | FAQs | Call for proposals

Spring 2025: Closed

The submission period closed on May 7.

AI for Information Security
Advancing possible solutions for some of the most challenging problems in information security.

Amazon Ads
Advancing customer protections in the era of artificial intelligence in digital advertising.

AWS AI: Agentic AI
Advancing the frontiers of AI.

Build on Trainium
Building the future of AI with AWS Trainium.

Think Big
Advancing the frontiers of science through transf

amazon | science

Research areas | Blog | Publications | Conferences | Code and datasets | Academia | Careers | Feedback

Amazon Research Awards

Program updates | Research stories | Recipients | Rules | FAQs | Call for proposals

Fall 2024: Closed

The submission period closed on November 13.

AI for Information Security
Advancing possible solutions for some of the most challenging problems in information security.

Automated Reasoning
Systems assurance by mathematical proof.

AWS AI
Advancing the frontiers of machine learning.

AWS Cryptography
Setting the standard for cryptography at Amazon.

Sustainability
Welcoming proposals related to data validation, life cycle assessment, biodiversity and more.

Spring 2024: Closed

The submission period closed on May 7.

AI for Information Security
Advancing possible solutions for some of the most challenging problems in information security.

Sustainability
Addressing the challenges associated with generating consistent, transparent, and accurate carbon measurements.

amazon | science

Research areas | Blog | Publications | Conferences | Code and datasets | Academia | Careers | Feedback

Amazon Research Awards

Program updates | Research stories | Recipients | Rules | FAQs | Call for proposals

Fall 2023: Closed

The submission period closed on November 13. Decision letters were sent out March 2024.

AI for Information Security
Helping customers achieve the highest levels of security in the cloud.

Automated Reasoning
Systems assurance by mathematical proof

AWS AI
Advancing the frontiers of machine learning.

AWS Cryptography and Privacy
Setting the standard for cryptography and privacy at Amazon.

AWS Database Services
Innovative approaches to designing, building, or operating large-scale database services or distributed cloud services.

Sustainability
Making Amazon the most environmentally and socially responsible place to buy or sell goods and services.

AWS Call for Proposal (Cont.)

https://www.amazon.science/research-awards/call-for-proposals

Spring 2022: Closed

The submission period closed July 15. Decisions letters were sent December 2022.

AI for Information Security
Advancing cybersecurity with AI

Alexa: Fairness in AI
Building AI for everyone

Amazon Science Community and Machine Learning University
Making Amazon the best place in the world to do customer-obsessed science and engineering

Amazon Advertising
Breakthroughs in online advertising

AWS AI: Human-in-the-loop machine learning and

Fall 2021: Closed

The submission period closed October 8. Decision letters were sent March 2022.

AI for Information Security
Advancing cybersecurity with AI

Data for Social Sustainability
Advancing the use of data science for social good

Amazon Device Security and Privacy
Enabling trustworthy compute environment from edge to cloud

Amazon Payments
Breakthroughs in security, verification, and anomaly detection

AWS AI
Advancing the frontiers of machine earning

AWS Automated Reasoning
Security assurance, backed by mathematical proof

Prime Video - Automating Quality Analysis & Delivery
Solving audio/video challenges with machine learning

Robotics
Pursuing the future of robotics research

Past CFPs

Amazon Advertising - Summer 2021
Breakthroughs in online advertising

Alexa Fairness in AI - Spring 2021
Building AI for everyone

AWS Automated Reasoning - Spring 2021
Security assurance, backed by mathematical proof

AI for Information Security - Fall 2020
Advancing cybersecurity with AI

Alexa Fairness in AI - Fall 2020
Building AI for everyone

Robotics - Fall 2020
Pursuing the future of robotics research

AWS AI - Fall 2020
Advancing the frontiers of machine learning

AWS Automated Reasoning - Fall 2020
Security assurance, backed by mathematical proof

AWS Call for Proposal (Cont.)

https://www.amazon.science/research-awards/call-for-proposals

AI for Information Security call for proposals — Spring 2025

- Agentic AI for security
- Generative AI and foundation models for information security
- Securing generative AI and foundation models
- Threat, intrusion and anomaly detection for cloud security
- Vulnerability detection and remediation using AI
- Incident response using AI
- Reinforcement learning for information security
- Learning with limited/noisy labels and weakly supervised learning
- Graph modeling and anomaly detection on graphs
- ML for malware analysis and detection, with a focus on cloud environments or devices

Thank You!